



A natural language-based method to specify privacy requirements: an evaluation with practitioners

Mariana Peixoto^{1,2} · Tony Gorschek³ · Daniel Mendez³ · Davide Fucci³ · Carla Silva²

Received: 31 January 2024 / Accepted: 3 July 2024 / Published online: 19 July 2024
© The Author(s), under exclusive licence to Springer-Verlag London Ltd., part of Springer Nature 2024

Abstract

Organisations are becoming concerned with effectively dealing with privacy-related requirements. Existing Requirements Engineering methods based on structured natural language suffer from several limitations both in eliciting and specifying privacy requirements. In our previous study, we proposed a structured natural-language approach called the “Privacy Criteria Method” (PCM), which demonstrates potential advantages over user stories. Our goal is to present a PCM evaluation that focused on the opinions of software practitioners from different companies on PCM’s ability to support the specification of privacy requirements and the quality of the privacy requirements specifications produced by these software practitioners. We conducted a multiple case study to evaluate PCM in four different industrial contexts. We gathered and analysed the opinions of 21 practitioners on PCM usage regarding *Coverage*, *Applicability*, *Usefulness*, and *Scalability*. Moreover, we assessed the syntactic and semantic quality of the PCM artifacts produced by these practitioners. PCM can aid developers in elaborating requirements specifications focused on privacy with good quality. The practitioners found PCM to be useful for their companies’ development processes. PCM is considered a promising method for specifying privacy requirements. Some slight extensions of PCM may be required to tailor the method to the characteristics of the company.

Keywords Privacy criteria method · Privacy requirements specification · Empirical study · Software development

Tony Gorschek, Daniel Mendez, Davide Fucci and Carla Silva are contributed equally to this work.

✉ Mariana Peixoto
mariana.peixoto@upe.br

Tony Gorschek
tony.gorschek@bth.se

Daniel Mendez
daniel.mendez@bth.se

Davide Fucci
davide.fucci@bth.se

Carla Silva
ctlls@cin.ufpe.br

¹ Universidade de Pernambuco (UPE), Garanhuns, Pernambuco, Brazil

² Centro de Informática, Universidade Federal de Pernambuco (UFPE), Recife, Pernambuco, Brazil

³ Department of Software Engineering, Blekinge Institute of Technology (BTH), Karlskrona, Sweden

1 Introduction

During software development, Non-Functional Requirements (NFRs) are usually neglected or receive just cursory treatment [1–6]. Privacy, in particular, is an NFR that has become a key concern in Software Engineering (SE) also driven by the growing demand to comply with privacy-related regulations and norms [7–10].

Personal data privacy can be defined as the right to determine when, how, and to what purpose personal information is communicated to others [11]. However, software development teams face problems with outdated privacy specifications [12]. For example, they consider user stories (one of the most common requirements specification techniques used by the industry) a threat to the proper implementation of data privacy because privacy requirements must be more detailed [5, 12, 13]. Another problem is that developers often do not have sufficient knowledge to specify privacy requirements [9, 14]. This often results in software products and services with limited considerations for privacy [15]. Moreover, problems with respect to compliance with

privacy laws may lead to rework, delays, and financial and legal repercussions [9, 10, 14, 16].

Several approaches have been proposed to deal with privacy issues in early stages of software development. For example, Gharib et al. [7] provide an ontology, whereas methods to include privacy in the RE process are proposed in other works [11, 17–19].

Further works include model-based approaches to specify privacy requirements, using, for example, Data Flow Diagram (DFD) [20], Business Process Model and Notation (BPMN) [21, 22], Non-Functional Requirement Framework (NFR), Tropos, and iStar framework [24, 24]. However, recent work on Requirements Engineering (RE) practices in the industry has found that natural language-based approaches are still the most popular ones [5], although there are many model-based approaches for requirements specification. Moreover, the literature contains few natural language-based approaches focused on privacy requirements specification that can be used integrated with mainstream requirements specification techniques, such as use cases and user stories. For example, an adaptation of User Stories for GDPR [25] was proposed in [26]. However, it is focused only on (part of) the European data protection law and does not cover other sources for privacy requirements (as the catalog of privacy concerns [27] or the privacy ontology [7]).

We proposed the Privacy Criteria Method (PCM) [28, 29] in the face of the lack of a natural language-based approach that could be integrated into mainstream requirements specification techniques and supports a more complete set of privacy concerns than the existing approaches. PCM is based on a catalog of privacy concerns [27] and also following the findings of our earlier empirical study about how software developers deal with privacy requirements [14, 30].

An initial evaluation of PCM was performed using a controlled experiment that compared using PCM along with User Stories by means of metrics defined to evaluate the quantity and quality of privacy requirements specifications. Also, we gathered the opinions of the experiment's participants regarding the ease of use and usefulness of PCM. The experiment's participants were 32 Information Technology analysts who were studying in a master's degree program at a Brazilian university. The experiment's findings have shown that PCM leads to specify more privacy requirements; the effort to use PCM is not bigger than using User Stories alone; PCM provides the constructs to specify privacy requirements from a system analyst's point of view; and the privacy requirements obtained using the method are of good quality [29].

As the evaluation study presented in [29] obtained promising results, we took a step forward and performed an evaluation of PCM in industrial settings. Therefore, this paper presents this empirical evaluation of PCM in four different industrial contexts which were interested in learning

new privacy engineering practices. The evaluation was performed by professionals of two Brazilian Research and Development (R & D) projects—R & D Project 01 (regarding company 1) and R & D Project 02 (regarding company 2)—and two Swedish companies, Ericsson¹ and Löf.²

Our manuscript is structured as follows. In Sect. 2, we present the study background and related work. In Sect. 3, we describe the research method. In Sect. 4, we present the data that we collected during the conduction of the study. In Sect. 5, we present our discussion of the study implications. Section 6 presents the threats to validity. Finally, in Sect. 7, we present our conclusions and suggest several directions for future research.

2 Background and related work

In this section, we briefly review the main themes supporting this research project, including Requirements Specification, and an explanation of privacy requirements specification with PCM. We conclude with a discussion of related work in this area.

2.1 Requirements specification

RE consists of a systematic and disciplined approach to the specification and management of requirements with the goal of understanding the stakeholders' desires and needs and minimizing the risk of delivering a system that does not meet these desires and needs [31].

In agile contexts, which is in the scope of our work, one prominent approach to specify requirements is given by elaborating user stories. The User Stories method (concise notation for expressing requirements) and Acceptance Criteria (description of a criteria that support the acceptance, or not, of a requirement) are commonly used to elaborate requirements specifications [32, 33].

A recent survey initiative to gather RE practices and problems experienced in industrial contexts reported that the most common practices regarding requirements representation format are (i) free-form textual domain/business process models, (ii) free-form textual requirements lists, (iii) use case models as “text with constraints”, and (iv) the textual documentation of NFRs [5]. The specification of NFRs (Non-Functional Requirements) is considered to be a challenge in Requirements Engineering [2, 3, 34–36], since recent studies suggest that software development methods tend to neglect NFRs due to the lack of elicitation and documentation techniques. This results in a very limited requirements documentation for capturing NFRs [2, 3, 34].

¹ www.ericsson.com.

² www.lof.se.

Moreover, developers often do not know how to deal with privacy [9] and lack techniques to specify privacy requirements [12]. Despite User Stories allowing to capture information about who should expect what from the system and why, according to [12, 13], they do not allow to detail privacy concerns. For example, in following the user story

US1. As a health care user, I want to share medical data, so that it can be properly presented to my doctor.

It is not possible to provide details about the privacy concerns regarding the action of registering “personal data”—such as deciding what data will be collected, what is the risk of collecting this information, and how to mitigate risk.

Expanding the user story format to allow for capturing such information is in the scope of the Privacy Criteria Method introduced next.

2.2 Privacy specification using privacy criteria method

Privacy Criteria Method is a structured, natural language-based method aimed to address industrial needs regarding privacy requirements specification [5, 14, 27, 32].

A good start to ensuring that NFRs are not neglected is considering quality factors for requirements specification. In this sense, we presented previously, Peixoto et al. [29] the results of a study that modeled factors that affect the quality of Software Requirements Specification (SRS) in agile development, including automated support, understandability, team-orientation, simplicity, and objectivity [32]. This model highlighted that specifying NFRs helps create a team-oriented SRS (with requirements described using language directed towards the developer) and, consequently, improves SRSs quality. This model resulted from a cross-case analysis and synthesis of six industrial case studies that adopted agile methods to develop software.

Moreover, we intended to contemplate current practices in software development [29]. For example, PCM is aimed to promote interactions between individuals and collaboration with the customer by promoting PCM as a guide to establish adequate privacy using a language that is easy to understand for the team and the customers. In addition, PCM only needs to be used when there is a need related to privacy, thus avoiding excessive documentation [29].

PCM includes documentation regarding how it can be used, a meta-model, a catalogue that lists privacy concepts, and an illustrative example [28, 29, 37]. In addition, we have developed a web-based³ Tool to support PCM [28, 37].

PCM can be considered to be a complementary approach because it can be used in conjunction with other

requirements specification methods, including user stories and acceptance criteria, use cases, etc [29]. In other words, PCM assists in the specification of privacy requirements (created by developers), as natural language-based requirements techniques fail to specify them, as evidenced in previous works [5, 9, 28, 29].

The PCM process begins when the software development team initially performs the system requirements specification activity, which can occur throughout the development process (e.g., in Agile) [29]. For example, considering the Scrum methodology, we can insert the PCM artifacts during the development of the Product Backlog/Sprint Backlog, which is when requirements are specified in Scrum (See Fig. 1). If the requirement to be specified in the Backlog involves the use, collection, retention, or disclosure of personal information, it is also necessary to initiate the specification with PCM (Table 1 explains the activities to create a PCM artifact). Otherwise, the specification activity is concluded.

In Fig. 2, we present an example of a requirement specification using PCM (i.e., a PCM artifact). The requirement delineates the functionality of sharing the medical data of a Healthcare system user (US1 shown in Sect. 2.1). In the scenario, the system allows the sharing of personal information and medical information of patients with their doctor. There are three actors involved in this system who relate to each other in a trust relationship: (1) the Information Owner (the healthcare user), the Processor (the system), and a Third Party (the assigned doctor).

Applying PCM Fig. 2, a photograph would be classified as Semi-Public information. A photograph that is collected for sharing (“The purpose of task context”) would be retained for two years (“How long?”).⁴

A risk scenario is created in response to the idea that a vulnerability (“Someone else may access/share user’s data”) is exploited by a threat (“Intrusion into the user’s life” and “Exposition of the user’s information”) can produce harm (“Intrusion may cause embarrassment to the user” or “Exposure of personal information may cause financial problems to the user”). In the next step, privacy mechanisms (“Provide awareness by presenting notification for the action” and “Get the user’s consent”) are created to mitigate the risk scenario.

2.3 Related work on privacy requirements

The RE community has recognized that privacy issues need to be addressed at the early stages of software development. Consequently, the RE community has created a number of valuable solutions to satisfy this need. In Table 2, we report on work regarding privacy in the requirements specification.

³ PCM Tool is available at: <http://privacy-criteria-v2.herokuapp.com/>.

⁴ In a PCM artifact, some privacy constraints are set by user preferences.

Fig. 1 The requirements specification process (Based on [29])

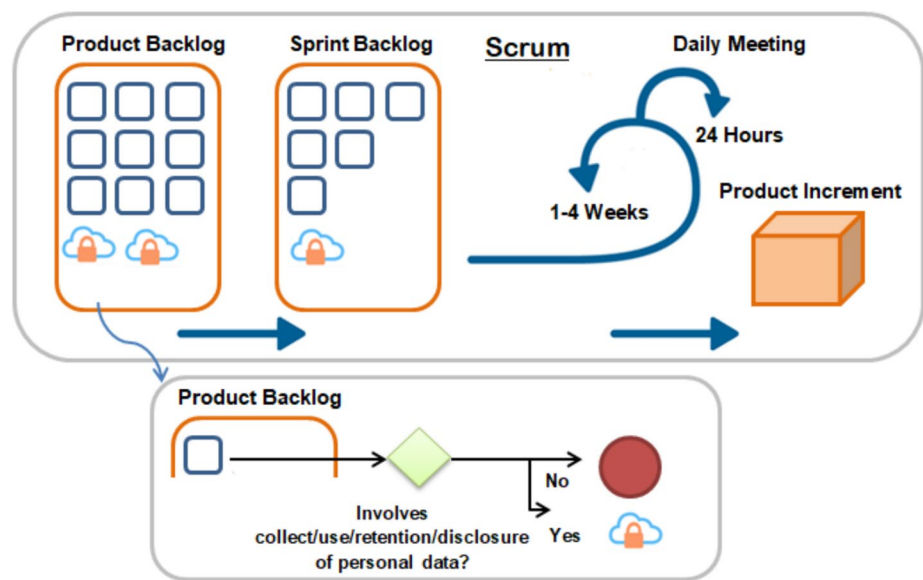


Table 1 The PCM process activities

Activity	Specification explanation
Specify description - basic information	ID (unique identifier of the privacy criteria) Privacy requirement and its description (detailed description of the specified requirement) Information source (person responsible for the information) Priority ('Low Critical', 'Regular', 'Critical', or 'Very Critical') Lawful base (example according to GDPR, consent, contract, legal obligation(s), vital interest(s), public task, and legitimate interest(s)). The legal basis that justifies the collection of information
Specify actors	Actors involved in the specific requirement: Owner/Controller, Processor, and Third Party
Specify the trust Relation of Actors	The relationship that indicates the trust that exists between actors regarding information disclosure (the trust that the owner of the information has in other actors to share information)
Specify personal information	All personal information related to the specific requirement. Each piece of personal information should be classified into one of the following types: private information, public information, or semi-public information
Specify the Purpose of Task Context	The purpose of each piece of personal information, as well as the information retention time
Specify privacy constraint(s)	According to the privacy preference that is selected and the privacy compliance/policy
Specify privacy risk scenario(s)	A risk scenario refers to the specification of potential vulnerabilities that can be exploited by potential threats that may cause potential harm, either individually or in combination with other threats
Specify the privacy mechanism(s)	The mechanism that can be used to mitigate the identified risk scenario or meet the privacy constraint

For example, the term *Privacy by Design* (PbD) arises from the need to propose privacy considerations throughout the information system development process [38]. PbD defines seven privacy principles that are relevant to the software development life-cycle. PbD, however, does not provide any particular specification technique or development method to support privacy specification.

Antón and Earp [39] focus on the initial specification of a security and privacy policy and its operationalization. This approach applies goal- and scenario-driven requirements engineering methods to secure electronic commerce

systems, resulting in the specification of privacy policies, security policies, and the corresponding system requirements. Ayed and Ghernaoui-Hélie [40] argue that the specification of privacy requirements should be drawn from global, domestic, and business-specific privacy policies. These approaches focus on privacy requirements that are present only in privacy policies but have not been evaluated empirically by software development practitioners.

Viitaniemi [41] has formulated a model for adhering to PbD principles in the context of "Scrum Development." Although Viitaniemi's study includes some predefined

Fig. 2 PCM artifact produced in specification

PCM Artifact				
ID (PCM01)	Source: Alice	Priority: Critical	Lawful base: Consent	
Privacy Requirement: (US01)		Description: The system must allow the option of sharing users' personal / medical data.		
1 - Actors			2 - Actors' Trust Relationship	
	Owner/Controller	Health Care User	System , Doctor	
	Processor	System	Doctor	
	Third Party	Doctor		
3- Personal Information			4 - The purpose of tasks Context	How long?
	Private			
	Public			
	Semi-Public	Photo, Full Name, Email Phone, Age, Gender, Blood Type, Weight, Height, Address, Allergies, Chronic Diseases	For sharing	2 years
5 - Privacy Constraint:	Privacy Preference	Doctor may not share the data without user consent		
	Privacy Compliance/Policy			
6 - Privacy Risk Scenario	Potential Vulnerability	EXPLORED BY	Potential Threat	
	Someone else may access/share user's data		- Intrusion in user's life; - Exposition of user's information.	
	CAUSE			
	Potential Harm			
	- Intrusion may cause embarrassment to User; - Exposure of personal information may cause problems.			
7 - Privacy Mechanisms	- Provide Awareness by presenting notification for the action; - Get users consent.			

Table 2 Overview of related work

Approach	Specification	Application to software development
Privacy by design (PbD) [38]	Not supported	It presents only guiding principles
Privacy policy [39]	It specifies privacy requirements using goal and scenario-driven requirements	It was not evaluated in multiple settings
Privacy specification View [40]	It specifies privacy requirements by classifying privacy policies according to specific groups	It was not evaluated in multiple settings
Agile privacy [41]	Not supported	It presents only guiding principles
Threat poker method [42]	Not Supported	It is a planning activity
Goals models [23, 24]	It specifies privacy requirements using models	It was not evaluated in multiple settings
Object-oriented languages (UML profiles cases, class diagrams, and use case specification) [43–45]	It specifies privacy requirements using models	It was not evaluated in multiple settings
BPMN extensions [21, 22, 46]	It specifies privacy requirements using models	It was not evaluated in multiple settings
SQUARE method [17]	Not supported	It defines activities only
LINDDUN method [20]	It uses data flow diagrams to support the analysis of privacy threats	It was evaluated by practitioners in multiple settings
GuideMe [18]	It specifies privacy requirements using a template	It was not evaluated in multiple settings
POSD [47]	It defines activities related to analysis, design, coding, verification, and validation without any specific strategy for specification	It was not evaluated in multiple settings
Requirements elicitation, analysis, and consolidation of DEFEND [48]	It defines a methodology and process to elicit, analyze, and consolidate requirements	It was not evaluated in multiple settings
A vulnerability-centric RE framework [19]	It provides a framework for analyzing security attacks, countermeasures, and requirements based on vulnerabilities	It was not evaluated in multiple settings
Data Protection backlogs [26]	It specifies privacy requirements using User Stories	It was not evaluated in multiple settings

privacy requirements (confidentiality, data minimization) that must be checked early in the development process, the author does not actually present *how* one might perform requirements specification. Rygge and Jøsang [42] describe the “Threat Poker Method,” which can be employed by Agile software design teams. Their method encourages developers to consider threats to security or privacy and evaluate ways to remove or mitigate vulnerabilities related to those threats. However, the Threat Poker Method only covers estimation for the implementation of security and privacy requirements in Agile development. Bartolini et al. [26] introduce the concept of “Data Protection Backlogs,” which are lists of User Stories about GDPR provisions. These are presented as technical requirements. Although their concept is promising, it focuses, however, on access control requirements from the GDPR and has not yet been evaluated empirically.

Privacy requirements can also be represented in goal-oriented modelling languages, such as Secure Tropos [23] and the iStar Framework [24], or in object-oriented and modelling languages, including the Unified Modeling Language (UML) [43], UML diagrams (as Use Cases [45] and Class Diagrams [44]). Further applications are given by languages for process modelling, for example, the Business Process Model and Notation (BPMN) [21, 46].

These approaches, although they seem promising, could, however, not yet be evaluated empirically rendering them as proposals with limited insights into how to apply them exactly and what their benefits and limitations are.

The Privacy SQUARE Method [17] adapts a security RE process to identify privacy requirements. The SQUARE further process consists of nine steps, including the definition of artifacts that will be used during the process, the elicitation and prioritization of requirements, and finally, the inspection of requirements.

The LINDDUN Method [20] covers privacy threat analysis, particularly during requirements elicitation. It consists of six steps, starting with creating data flow diagrams, using a threat analysis framework to elicit software privacy requirements, and concluding with selecting relevant privacy-enhancing technologies.

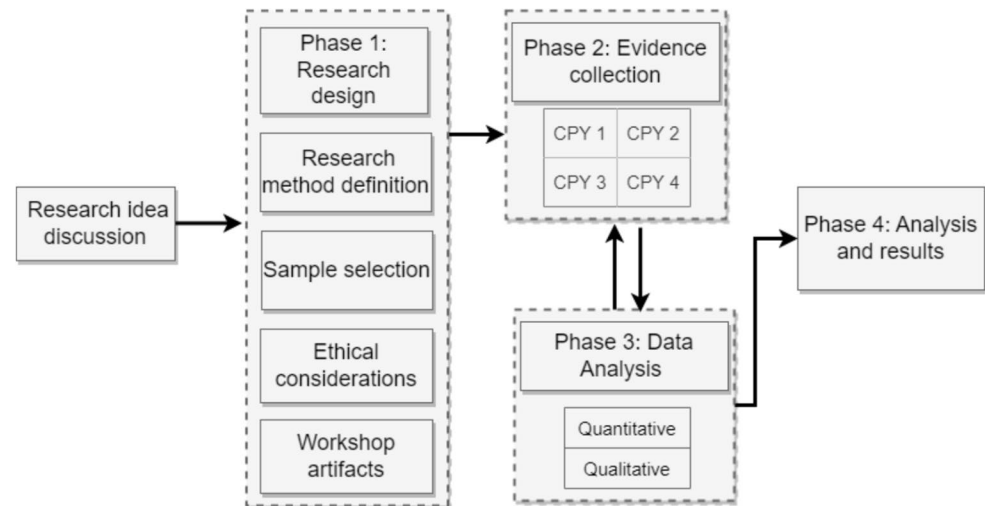
The GuideMe [18] supports business and solution requirements elicitation and specification in compliance with GDPR.

Baldassarre et al. [47] have proposed an approach called “Privacy Oriented Software Development” (POSD) to complement traditional development processes with security and privacy management. This approach includes five key elements: (i) Privacy by Design, (ii) Privacy Design Strategies,

Table 3 Companies involved in the multiple case study

	R &D project 01	Ericsson	R &D project 02	Löf
Domain	Telecommuni-cations*	Telecommuni-cations**	Telecommuni-cations*	Health insurance
Size***	Very Large	Very Large	Very Large	Medium

*Practitioners from an R &D project developed in partnership with a mobile device manufacturer. **Information and Communication Technology (ICT). ***According to the number of employees: Medium < 500; Very Large > 1000

Fig. 3 Research overview

(iii) Privacy Pattern, (iv) Vulnerabilities, and (v) Context. In the context of the DEFEND EU project, Tsohou et al. [48] provide a methodology and process for the elicitation of users' needs. They also provide a way in which one can analyze and consolidate requirements for a GDPR compliance platform. Their approach spans multiple aspects of user needs, including functional, security, privacy, legal, and acceptance requirements. Elahi et al. [19] propose a vulnerability-centric requirements engineering framework that offers modeling and analysis facilities to assist in analyzing vulnerabilities and their effects on the system.

Although these approaches were proposed to better deal with privacy requirements in software projects, many of them are specific to GDPR compliance and are model-based (what makes their adoption in the industry harder as natural language-based approaches are mainstream [5]). In addition, they weren't evaluated either by an experiment or by software development practitioners from multiple companies and in different settings. LINDDUN, for example, is a model-based approach evaluated only regarding usefulness by practitioners by means of a questionnaire [49]. User Stories for GDPR [26], in turn, is a natural language-based approach covering part of GDPR but wasn't empirically evaluated. Therefore, we do not have evidence for any of these approaches, showing their overall evaluation regarding: usefulness, easiness of use, quality of the specifications created, support to Requirements Engineering activities integrated to techniques and technologies already

adopted by real-world projects (such as User Stories, UML, Scrum, requirements management systems, etc.), according to software practitioners' opinions.

Our work is worth noting that PCM was conceived to address the recommendations of Privacy by Design, which indicates the necessity of considering privacy from the early stages of software development, specifically in the RE phase. This underscores the importance of integrating privacy considerations seamlessly into the beginning of the software development lifecycle to ensure the creation of privacy-respecting software systems [29]. PCM, in addition to promoting the creation of more privacy-focused requirements specifications using a natural language-based approach was considered useful and easy to use [29]. Moreover, we have evidence of its potential to be integrated into techniques and technologies already adopted by real-world projects, as shown by the findings presented in [29] and in the new evaluation detailed in this paper.

3 Research method

In our study, we evaluate PCM in an industrial context from the point of view of industry practitioners. We performed a multiple case study at four companies (see Table 3) following the guidelines of Runeson and Höst [50] and Svensson et al. [51]. These procedures included (i) Study design—during which the study's goals are defined, and the study

Table 4 Metrics utilized in the empirical study

Metric	Description	Ref.
<i>Quality specifications</i>	Refers to the quality of the specifications produced by the study participants using PCM during a practical task (in terms of (Syntactic - Well-formed, Atomic and Minimal) and (Semantics - Conceptually sound and Problem-oriented))	[33]
<i>Coverage</i>	To ensure PCM provides the constructs that are needed to specify privacy requirements and also to detect other constructs that the practitioners omitted in the PCM structure	[54] and [53]
<i>Usefulness</i>	To collect the practitioner's opinion about whether PCM is useful to help in privacy specification activity in an industrial setting	[54] and [53]
<i>Applicability</i>	To collect the practitioner's opinion about whether PCM can be applied in an industrial setting	[54] and [53]
<i>Scalability</i>	To collect the professional's opinion about whether the PCM can be scalable for projects in an industrial environment	[54]

is planned; (ii) Collecting evidence-conducting the study, including data collection; and (iii) Analysis of the collected data (see Fig. 3).

3.1 Study goal and questions

The goal of our study is described using the Goal-Question-Metrics approach [52].

Analyze PCM's potential to specify privacy requirements for the purpose of creating specifications addressing industry needs with respect to quality and coverage of the produced specifications, as well as applicability, usefulness and scalability of the method from the point of view of industry practitioners.

Our evaluation was guided by the following Research Questions (RQ):

RQ1: What is the quality of the specifications that were obtained using PCM? This question aims to collect information about the quality that can be indicative of a greater detailing of the artifacts.

RQ2: What is the coverage of the privacy concerns in the specifications that were obtained using PCM? This question aims to collect information on the extent to which PCM covers privacy specifications.

RQ3: How useful is PCM from the practitioners' point of view? This question aims to collect information on whether PCM is useful to be introduced during the development process.

RQ4: How applicable is PCM from the practitioners' point of view? This question is intended to collect information about the extent to which PCM can be applied in the development process.

RQ5: What are privacy concerns either missing or considered to be excessive in the PCM structure? This question aims to collect information on whether, according to participants' experience, they believe they can include or remove some structure from the PCM (When too much or too little information is gathered for all of the concerns).

RQ6: How scalable is PCM from the practitioners' point of view? This question is intended to collect information on whether, based on expectations and experience, participants believe that PCM can be scalable within the development.

3.2 Metrics and procedures

In this study, we aim to evaluate the PCM by assessing the software practitioner's opinion on the ability of PCM to support privacy requirements specification and the privacy specification quality generated by practitioners when using PCM. Our analysis includes consideration of Coverage, Applicability, Usefulness, Scalability, and PCM's ability to produce Quality specifications from the point of view of a team developing privacy-sensitive software. [53] created metrics for evaluating safety practices in the context of requirements engineering. [54] created metrics for evaluating requirements in the engineering process. Lastly, [33] created quality metrics to evaluate specifications with User Stories. These metrics evaluate the syntactic quality of User Stories as well as the semantic quality of User Stories, which concerns the meaning of (parts of) the User Stories text. Our metrics are described in Table 4.

In Table 5, we detail the metrics that we use to measure the quality of the specifications produced in our case studies.

We justify the choice of these metrics (see Table 4) because we used them in a previous PCM evaluation provided by [29]. In addition, the usage of metrics such as Coverage, Applicability, Usefulness, Scalability, and Quality proved seamless, given their established usage in the requirements specification field. It means that the usage of these metrics facilitates replication, as the effortless integration of these metrics, with their established use in similar domains, simplifies the application of the methodology in diverse contexts within requirements specification.

We used purposive sampling as a selection strategy with our industrial collaboration network to find practitioners as the study subjects. According to [55], purposive sampling

Table 5 PCM quality metrics of the practitioners' evaluations

Metric	Explanation	Details
<i>Syntactic</i>		
Well-formed	Correct well-formed = 7	A PCM artifact includes at least one of the following seven elements: at least 1 actor; 1 trust relationship, 1 personal information, 1 purpose context, 1 privacy constraint, 1 risk scenario, and 1 privacy mechanism. Each element is scored cumulatively: The artifact does not contain the relevant element = 0; The relevant element is not clear = 0.5; The artifact contains the relevant element = 1. The maximum score a PCM artifact can score is 7
Atomic	Correct atomic = 1	A PCM artifact expresses a requirement for precisely one feature. For this category, the PCM artifact is scored as follows: - The PCM artifact does not express a requirement for exactly one feature = 0; The requirement is not clear = 0.5; The PCM artifact clearly expresses a requirement for exactly one feature = 0. The maximum score for this category of analysis is 1
Minimal	Correct minimal = 1	A PCM artifact contains nothing more than the following elements: actor, trust relationship, personal information, purpose context, privacy constraint, risk scenario, and privacy mechanism. The following scoring procedure was followed for this category: There are more elements than those listed above = 0; It is not clear what number of elements are listed = 0.5; No more elements than those listed above are present in the PCM artifact = 1. The maximum score for this category is 1
<i>Semantics</i>		
Conceptually sound	Correct conceptually sound = 7	Each one of the PCM elements (i.e., actor, trust relationship, personal information, purpose context, privacy constraint, risk scenario and privacy mechanism) expresses its purpose exactly. Each element was scored according to the following: -the PCM element does not express its purpose = 0; -The PCM element does not clearly express its purpose = 0.5- The PCM element expresses its purpose exactly. The maximum score that can be achieved in this category is 7
Problem-oriented	Correct problem-oriented = 1	The PCM privacy mechanism mitigates the privacy constraint or the risk scenario. This element is scored as follows: The PCM privacy mechanism does not mitigate the privacy constraint or the risk scenario = 0; The PCM privacy mechanism is not clear = 0.5; -The PCM privacy mechanism mitigates the privacy constraint or the risk scenario = 1). The maximum score for this category is 1. If more than one privacy mechanism is present in the element, then it is necessary to calculate the average

Adapted from [33]

is a type of non-probabilistic sampling used in Software Engineering in that subjects are selected according to some strategy, carefully but not randomly. When planning the study, we sent to twenty companies, a one-page document describing the PCM's motivation and objective. We also described the potential benefits of participating in this study. The companies were free to decide which of their representatives would participate in the study. The researchers did not influence the selection of the participants, nor did the researchers have any previous personal relationship with the participants. Regarding the participant sample, we did not restrict participation based on any specific role. We aimed to gather insights from individuals who are actively involved in the software development process and have access to requirements documentation, i.e., different roles [56]. Many companies do not have the traditional role of a requirements engineer, but often other roles take over those responsibilities [57]. Also, practitioners could confuse the concepts of role (a function or part performed especially in a particular operation or process) and position (employment for which one has been hired)

[57]. This implies that companies assign IT professionals to the role of Requirements Engineer in their projects [57].

Although we present the names of two (out of four) companies, for reasons of confidentiality, we have not directly linked the companies' names to our results. To ensure anonymity, we have referred to the participating companies as Company 1 (CPY1), Company 2 (CPY2), Company 3 (CPY3), and Company 4 (CPY4) without linking these anonymous to the companies described (in no particular order) in Table 3. In total, twenty-one practitioners participated in this study. Three participants were from CPY1, five from CPY2, nine from CPY3, and four from CPY4. Also, for confidentiality reasons, we do not collect the details of the participant's work (e.g., products and services under development) (Table 6).

3.3 Workshop execution and data collection

We collected data during workshops using a five-step strategy. In the first step, we used a pre-questionnaire (15 min) (See Supplementary materials) to collect information

Table 6 Summary overview of the participating companies

Company	Participant roles (years of experience)	Development practices used	Privacy documentation
Company 1	Epic owner (+15), product manager (+15), and Architect* (11–15)	Scrum, DevOps and Kanban	Privacy analysis, use cases/user stories and template for classification of data privacy
Company 2	Developer (11–15), Requirements engineer (1–5), steering committee member (6–10), test manager/tester (+15), and product manager (6–10)	Scrum, DevOps, feature-driven development and Agile (with waterfall parts)	Use cases/user stories
Company 3	Developer (1–5), Developer (1–5), Developer (1–5), Developer (1–5), Developer (6–10), Developer (6–10), Designer (1–5), Designer (1–5), and Iteration Lead** (6–10)	Scrum, DevOps, Lean Development, Kanban and Extreme Programming	Use Cases/User Stories, Free-form Textual Ways, and Models
Company 4	Iteration Lead** (1–5), Test Manager/Tester (1–5), Developer and Test Manager/Tester (11–15), and Developer (1–5)	Scrum	In Free-form Textual Ways

For reasons of confidentiality, we have not linked the real company names to our results. Instead, we refer to ‘Company 1’, ‘Company 2’, ‘Company 3’, and ‘Company 4’. *System Manager. **Iteration Manager/Scrum Master/Project Manager

about the participants’ profiles and information about how the software developers at these companies deal with the issue of privacy in software development, we also collect developers’ knowledge of privacy (including their understanding of privacy, their behaviour concerning privacy, and existing organizational procedures with relation to privacy). In the second step, we presented a motivation of the privacy importance, information about privacy in Software Engineering. During the seminar, we introduced the PCM approach (10 min). In particular, we showed PCM and practical examples using PCM. The case examples that we used in the seminar included a healthcare system scenario and a payment system at a pharmacy. In the third step, we asked the participants to perform a task (60 min) in which they should specify a real software requirement from their current project by using PCM. In the fourth step, we asked participants to answer a post-questionnaire (25 min) (See (See Supplementary materials)). In the final step of the workshop, we opened up a session for discussion (15 min). We took notes during the workshops and from the open discussions that began after the end of the post-questionnaire. We believe that these notes are essential to capture some information that may have been overlooked during the sessions, as well as to collect more information about the participants’ perception of PCM improvements that may arise through insights that we did not collect in the questionnaires. A total of 125 min was spent during each workshop. At least two authors were present during each workshop (the first author participated in all workshops).

Two authors conducted data analysis, which was validated by the remaining ones. The authors leading the analysis brought valuable expertise to the metrics, derived from prior application in earlier study [29]. We did not engage in discussions with the subjects regarding the results. Nevertheless, an internal discussion took place, allowing for a

Table 7 Mapping of data sources in research questions

Data sources	Research question
Pre-questionnaire	Demographics (work characterization) and Privacy characterization
Task	RQ1
Post-questionnaire	RQ2, RQ3, RQ4 and RQ5
Open discussion	RQ5 and RQ6

thorough analysis and examination of the obtained results. This internal discourse ensured a comprehensive understanding of the findings and their potential implications.

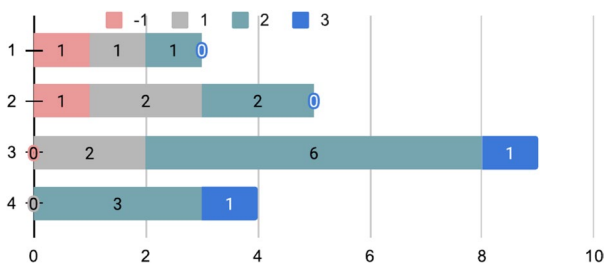
3.4 Data overview

In the pre-questionnaire, we collected information about the demographics of the participants and their understanding of the issue of privacy. We analyzed responses to quantitative and qualitative questions because the metrics we used are situated with both types. For the quantitative questions, we present a descriptive analysis of answer frequencies and percentages in terms of the total number of participants and by company. For the qualitative questions, we present results using thematic analysis following the steps indicated by [58]: Initial reading of data/text; Identify specific segments of text; Label the segments of text; Reduce overlap and translate; codes into themes, and Create higher-order themes.

Regarding the task (step 3), we analyzed the quality of the privacy requirements that participants specified with PCM. We measured the quality of these requirements by adapting the metrics provided by [33] (Table 5). In the

Table 8 Distribution of participant's roles

Role	CPY1	CPY2	CPY3	CPY4	Total	%
Architect	1	0	0	0	1	4.8
Developer	0	1	6	2	9	42.9
Epic owner	1	0	0	0	1	4.8
Iteration lead/iteration manager/ scrum master/project manager	0	0	1	1	2	9.5
Designer	0	0	2	0	2	9.5
Steering committee	0	1	0	0	1	4.8
Product manager	1	1	0	0	2	9.5
Requirements engineer	0	1	0	0	1	4.8
Test manager/tester	0	1	0	1	2	9.5
Total	3	5	9	4	21	100.0

**Fig. 4** Participant's perception of working in an Agile way

post-questionnaire, the answer options are distributed across a 7-point scale. This scale ranged from -3 “not entirely true for me” to +3 “totally true for me.” We separated the participants into four groups, representing the different companies involved.

With respect to the open discussion that we conducted in the workshops, we analyzed the notes that we (as researchers) collected during these sessions. We performed a thematic analysis. We coded the notes and three different categories emerged during the course of this process. These were: (i) questions from the participants, (ii) perceptions from the researchers' point of view, and (iii) suggested improvements from the participants.

4 Analysis and results

This section presents our analysis and results according to the steps that we performed during the workshops. The four distinct steps include (i) pre-questionnaire, (ii) task, (iii) post-questionnaire, and (iv) open discussion. We also report on the observations made by the researchers involved in the workshops that were conducted at each company.

In Table 7, we show how we used each data source to answer the RQs.

4.1 Pre-questionnaire analysis and results

In the pre-questionnaire, we asked questions about Demographics (Work Characterization) and Privacy Characterization.

4.1.1 Demographics characterization

We show nine different roles reported on in the four companies (Table 8). The role of the developer was the most frequent among our participants. The architect informed us that they also had the role of system manager. One of the developers reported that they were also a test manager.

Regarding the participants' experience, we found that three participants had between 11 and 15 years of experience, three had more than 15 years, five had between 6 and 10 years, and ten had between 1 and 5 years.

We asked the participants about their perceptions of the software process used in their companies and how their team works in an Agile way. We questioned the participant's Agile perception of working on a 7-point-Likert scale from -3 (not Agile at all) to +3 (Completely Agile) (Fig. 4). We asked this question because we already knew in advance that their teams were agile, but we did not know which agile practices they used. On a scale of -3 to +3, the participants from Company 1 and Company 2 shared similar perceptions regarding this factor (median = 1), while participants from Company 3 and Company 4 (median = 2) were more aware of working in an Agile way. Note that -3, -2 and 0 did not get answers, that is, they represent 0 (0.0%).

The questionnaire included other questions about Agile practices and asked the participants which Agile practices were closest to those practiced by the participants. Twenty participants reported that they used Scrum. Some of the participants also related Scrum to other practices. The following practices were reported: Agile waterfall (1 participant), DevOps (6 participants), Feature-driven development

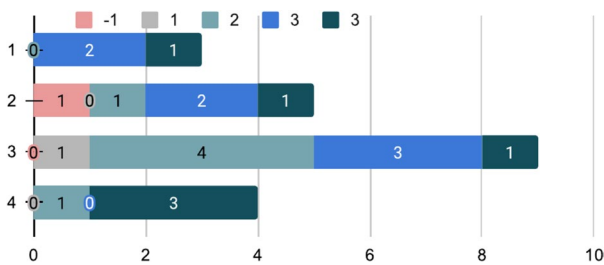


Fig. 5 Participant's perception of privacy

(1 participant), Lean Development (2 participants), Kanban (6 participants), and Extreme Programming (1 participant).

The practitioners' perception of how their teams work in an Agile way was further investigated in another question. According to the responses that we received, Company 1's teams worked with and planned 'sprints' during which they engaged in: Requirements, Effort, Design, and Test. Company 2's teams also worked with and planned sprints, including daily standup meetings, Requirements specification, Code reviews, and Retrospective. Company 2 also managed the backlog with the product owner. Company 3 teams used a Kanban activities board and Daily meetings to solve production impediments. Consequently, they worked with Daily and Retrospective meetings, Sprint Planning, Pair programming, Code reviews, and Constant feedback. Company 4's teams worked with remote meetings and sprints of one/two weeks, during which Daily, Retrospective, Review, and Planning meetings took place, and Prioritization and Estimation activities were conducted.

4.1.2 Privacy characterization

We asked the participants how they describe their team views about privacy during software development. Company 1 reported that they used organizational procedures to protect personal data to deal with privacy and searchability trade-offs. They viewed privacy as consisting of GDPR compliance, taking care of data minimization, using encryption of data, and implementing pseudo-anonymization. For example, one participant from this company mentioned: "We respect privacy... There are requirements, frameworks, and design rules created to protect personal data." Company 2 described the concept of privacy in terms of protecting a customer's data from security risks. They viewed privacy as GDPR compliance, the use of access control, and encrypted web communication procedures. One of the participants from this company reported "We take responsibility for which person can use the system and what that person needs to see." Company 3 described the concept of privacy as taking advantage of security organizational norms of user data to prevent any information leakage. Some participants

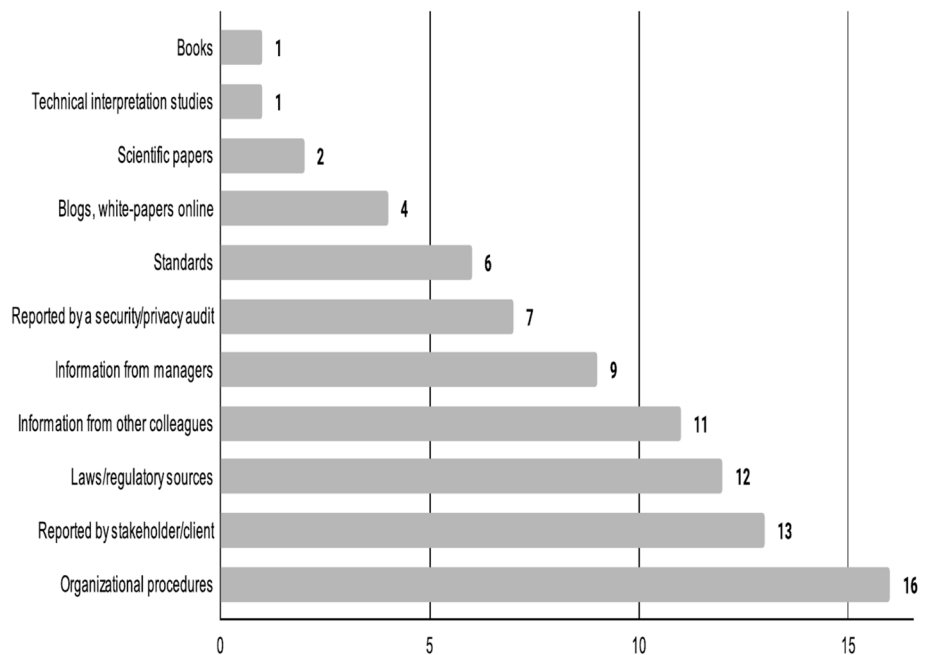
believed that privacy entailed being careful about user data, considering sensitive user data, or that privacy is the right to access data. Other participants suggested that privacy is linked to the limitation of access among company employees concerning secrets associated with new application development. One participant from Company 3 said "Other teams cannot analyze or support the project if permission is not granted." For Company 4, privacy was considered relevant to user information and the confidentiality of company secrets. One of their representatives commented that "When signing the employment contract, all employees must sign a confidentiality agreement."

Further, we investigated the extent to which the companies' team considered privacy when developing a product or service. We questioned the participant's perception of how privacy is considered by the team on a 7-point Likert scale from -3 (my team does not consider 'privacy' at all) to +3 (my team considers 'privacy' in its totality) (Fig. 5). Participants from Company 1 and Company 2 shared similar perceptions concerning the concept of privacy (median = 2), while participants from Company 3 (median = 1) were less concerned with privacy in contrast to Company 4, which demonstrated the highest degree of concern with privacy (median = 3). Note that -3 did not get answers, that is, they represent 0 (0.0%).

We observed that Company 1 considered privacy to some degree of depth because they have a team that worked directly with security issues. They considered privacy requirements late in the design process and followed a template that focused their attention on issues related to data privacy and how they can mitigate privacy problems in conjunction with possible privacy risks. Developers at Company 2 considered privacy as they were aware of compliance and access control to sensitive data in the development process. For example, Participant 2.3 from Company 2 stated: "We are handling the privacy question from a holistic perspective by involving compliance but also in the development process." Company 3's team accounted for privacy in the context of their work on security requirements of personal data. These team members reported that they were transparent with their users about how the system would use personal data and data transmission protection.

We asked the participants about the sources of information that they used to address privacy concerns. We identified eleven different sources that the participants used (See Fig. 6). We also observed that the participants held different views on the types of information sources that they used. Participant 1 from Company 1 believed in the existence of a hierarchy of information sources. For example, Participant 2.5 from Company 2 reported: "We have a strong risk management system implemented where risks and mitigation are detailed." The participants claimed that they trusted in their organizational procedures. Participants revealed to us that

Fig. 6 Sources of information used to address privacy concerns



they change information sources to address privacy concerns according to the product/service. For example, Participant 3.5 from Company 3 informed us: “*We generally analyze the need for each project [...]*”.

We asked the participants how they document privacy requirements. Company 1 documented privacy requirements in terms of use cases and user stories. They also have a template for privacy. Company 2 also uses use cases and user stories. Company 3 documented privacy requirements in free-form textual ways, models, use cases, and user stories. However, one participant claimed that they do not document privacy requirements. Company 4 used free-form textual ways to document privacy requirements, but two participants stated that they did not document privacy requirements at all. User stories constituted the type of documentation that the participants most frequently cited. In addition to the forms of the documentation presented above, participants from Company 1 also reported that a relevant template could be considered a document that explains how practitioners will treat and protect privacy. Company 2 followed a privacy requirements information model. Company 3 used user stories for privacy if the client asked for this to be done, as revealed by the response of one participant. Participants at Company 4 do not document privacy requirements. The participant, whose role is tester, informed that they receive software documentation to write different types of test cases (some cases included privacy needs in a textual way, as indicated by the response of one participant). Regarding participants who do not document privacy requirements, their interest in participating in the workshop we organized was driven by their desire to initiate the process of specifying privacy

requirements. Conversely, they possessed experience in specifying functional requirements. Therefore, the sample of Company 4 indicates that they constitute a sample that is exposed to specifications despite not being directly involved in their creation.

Finally, we asked the participants whether they used any specific tool or method (UML, User Stories, Scenarios, etc.) to analyze privacy aspects during the software development process. Fifteen participants responded to this question. All three participants of Company 1 said they used a tool or method for this purpose. In Company 2, only one participant stated that they do not use one. In Company 3, five participants said they used a relevant tool or method. Finally, in Company 4, only one participant stated they used a tool or method.

Regarding documenting privacy requirements. A participant at Company 1 stated that they used an MS Excel formula. In addition to user stories, Company 1 and Company 2 stated that a process of privacy analysis occurs during the requirements and testing phase. One participant from Company 4 stated that product managers reviewed privacy requirements.

4.2 Task analysis and results

In this section, we present the results of the task that was completed by the participants during the workshop (See Table 9). We use the results from this task to answer RQ1—i.e., the quality of the specifications obtained using PCM. During this step, we asked participants to work in pairs or groups of three when possible. After that, we asked for at least one *actual* specification of a privacy requirement using

Table 9 Quality of the PCM artifacts specified by participants

CPY	Well-formed	Atomic	Minimal	Conceptually sound	Problem-oriented	Total
1	5.50	1.00	1.00	4.50	0.50	12.50
1	5.50	1.00	0.50	5.00	1.00	13.00
2	6.50	1.00	1.00	6.00	0.50	15.00
2	7.00	1.00	1.00	6.50	1.00	16.50
2	7.00	1.00	1.00	5.00	1.00	15.00
2	6.50	0.50	1.00	6.00	1.00	15.00
2	7.00	1.00	1.00	7.00	1.00	17.00
2	7.00	0.50	1.00	7.00	1.00	16.50
3	7.00	1.00	1.00	7.00	1.00	17.00
3	7.00	1.00	1.00	6.00	1.00	16.00
3	7.00	0.50	1.00	7.00	1.00	16.50
3	7.00	1.00	1.00	6.50	1.00	16.50
3	6.00	0.50	1.00	6.00	0.50	14.00
4	7.00	1.00	1.00	6.50	1.00	16.50
4	7.00	0.50	1.00	6.00	1.00	15.50
Avg	6.67	0.83	0.97	6.13	0.90	15.50
Stdev	0.56	0.24	0.13	0.79	0.20	1.41

the PCM Tool (some pairs/groups performed more than one specification). In total, the participants constructed 15 PCM artifacts.

For Syntactic quality, we observed the metrics according to *Well-formed*, *Atomic*, and *Minimal*. For Semantics quality, we observe the metrics according to *Conceptually sound* and *Problem-oriented*.

The *Well-formed* metric average was 6.67 (10 out of 15 PCM artifacts were entirely correct). The average of each PCM element of all analyzed artifacts 1.00 for ‘actor’, 0.93 for ‘trust relationship’, 0.90 for ‘personal information’, 0.87 for ‘purpose context’, 1.00 for ‘privacy constraint’, 0.97 for ‘risk scenario’, and 1.00 for ‘privacy mechanism’. The results suggest that the participants created more *Well-formed* that were correct than incorrect ones. The *Atomic* metric indicated an average of 0.83 (10 out of 15 PCM artifacts were entirely correct). This result suggests that the participants created more *Atomic* elements correctly than they did incorrectly. The *Minimal* metric produced an average of 0.97 (14 out of 15 PCM artifacts were correct). The *Problem-oriented* metric resulted in an average of 0.90 (12 out of 15 PCM artifacts were entirely correct). This result suggests that the participants created more *Problem-oriented* elements correctly than incorrectly.

In conclusion, participants can use PCM to create *Well-formed*, *Atomic*, *Minimal*, and *Problem-oriented* elements.

The *Conceptually sound* metric resulted in an average of 6.13. The averages of each PCM element of all of the analyzed artifacts were 0.96 for ‘actor’, 0.87 for ‘trust relationship’, 0.83 for ‘personal information’, 0.87 for ‘purpose context’, 0.800 for ‘privacy constraint’, 0.83 for ‘risk

scenario’, and 0.97 for ‘privacy mechanism’. These results suggest that participants created more *Conceptually sound* elements incorrectly than correctly (4 out of 15 PCM artifacts were entirely correct). Therefore, four *Conceptually sound* elements presented the maximum score (7.00), three *Conceptually sound* elements presented a score of 6.50, and five *Conceptually sound* elements presented a score of 6.00. Thus, 12 PCM artifacts (out of 15) scored above 6.00. Although we cannot confirm the best scores of *Conceptually sound* elements, many participants specified individual PCM elements correctly.

The results suggest that the participants were able to create a specification with good Syntactic quality (*Well-formed*, *Atomic* and *Minimal*) and Semantics quality (*Conceptually sound* and *Problem-oriented*). For the example shown in Fig. 7, the task results were *Well-formed*- 7.0; *Atomic*- 1.0; *Minimal*- 1.0; *Problem-Oriented*- 1.0; *Conceptually sound*- 6.0.

4.3 Post-questionnaire analysis and results

In this section, we report the opinions of the 21 participants who answered the post-questionnaire.

4.3.1 PCM privacy coverage and PCM structure

In addition to the results presented in Table 10, we asked the participants whether they would add any privacy field(s) that is (are) not covered in PCM.

Participant 1.1 at Company 1 reported on information categories that can be considered personal (for example, call

Fig. 7 An example of a PCM artifact produced by practitioners

PCM Artifact						
ID (PCM02)		Source: GDPR	Priority: -		Lawful base: -	
Privacy Requirement: (US02)			Description: The system must allow the option of sharing users' personal / medical data.			
1 - Actors				2 - Actors' Trust Relationship		
	Owner/Controller	User		System		
	Processor	Application/System		Provider		
	Third Party	Content Provider				
3- Personal Information				4 - The purpose of tasks Context	How long?	
	Private	Profile information		To trace usage profile		
	Public					
	Semi-Public	Usage habits		To update the content	Contract duration	
5 - Privacy Constraint:	Privacy Preference					
	Privacy Compliance/Policy	Prior consent to use the information				
6 - Privacy Risk Scenario	Potential Vulnerability	EXPLORED BY		Potential Threat		
	Attacks influencing the generation of false data			Competitors of content presentation		
	CAUSE					
	Potential Harm					
	- User exposure; - Shame; - Prejudice					
7 - Privacy Mechanisms	- Consent; - Pseudo Anonymity.					

Table 10 Evaluation related to the participants' perception concerning how items of the PCM are useful

Usefulness of PCM elements	Median	Company	Median
Lawful base	3.0	CPY1	3.0
		CPY2	2.0
		CPY3	3.0
		CPY4	2.0
Actors and trust relation	3.0	CPY1	3.0
		CPY2	3.0
		CPY3	3.0
		CPY4	2.0
Personal inform. List	3.0	CPY1	3.0
		CPY2	2.0
		CPY3	3.0
		CPY4	3.0
Purpose of personal Inform. Context	3.0	CPY1	3.0
		CPY2	2.0
		CPY3	3.0
		CPY4	2.5
Privacy constraint	3.0	CPY1	3.0
		CPY2	2.0
		CPY3	3.0
		CPY4	2.5
Privacy risk scenario	3.0	CPY1	3.0
		CPY2	2.0
		CPY3	3.0
		CPY4	3.0
Privacy mechanisms	2.5	CPY1	3.0
		CPY2	2.0
		CPY3	3.0
		CPY4	2.5

records, medical test reports, the user's passport number, the user's social security number, and non-resident identifier). Participant 2.1 at Company 2 stated that the PCM Tool should be integrated with common company development techniques. For example, They stated: *"To be able to use PCM, I would like to add acceptance criteria and present the requirement status (new, closed, etc). So the developer can use the systems 'together' and show progress while developing. I would like to link it to test scenario development. One system for planning, development, and testing"*. Participant 3.1 indicated that they would add an indication of the types of data the user would accept to be displayed. Participant 3.4

would add the time taken to track user actions. Participant 4.1 at Company 4 said that essential parts of a product often come from a third company. For example, *"Perhaps [PCM should have] a field to detail restrictions [...] that a tertiary [company] should adopt [in the products it provides]. This would serve as a criterion by which a tertiary [company] from a set [of companies] can be selected."*

We asked the participants whether there were any privacy elements they could have forgotten if they did not use the PCM. Participants at Company 2 stated that they could have forgotten the different types of actors and different types of personal information without PCM. For example, Participant 2.2 from Company 2 said: *"I would have worked inconsistently with the elements and perhaps would have created conflicts"*. Participants from Company 3 stated that they might have forgotten privacy preferences, privacy constraints, privacy risk scenarios, retention time, actors, actors' trust relationship, and certain privacy mechanisms (for example, the provision of consent) without PCM. Participants from Company 4 stated that they could have forgotten issues relevant to the lawful base, actors, actors' trust relationship, and user preferences without PCM.

Finally, we asked participants for further comments about PCM. Participants at Company 2 raised a number of points concerning integration with company procedures. Participants from Company 3 and Company 4 praised PCM. For example, Participant 3.2 from Company 3 commented: *"I think that the items are very cool, and they make you think and pay attention to situations that we may not think about during our daily work."* However, Company 3 suggested several improvements that could be made regarding the PCM design, how specific fields are filled in, and increasing the number of support materials.

4.3.2 PCM usefulness

In Table 10, we are concerned with how important the participants think certain elements of PCM are. We observed a median between 2.5 and 3.0 when we considered all the participants' responses regarding the usefulness of PCM. Considering each company separately, we observe medians between 2.0 and 3.0.

Those results suggest that participants from all companies have similar perceptions.

Based on Table 10., we conclude that all PCM items are perceived as useful (RQ3).

4.3.3 PCM applicability

In Table 11, we present the participants' responses with respect to their perception of: How easy the PCM is to use; Privacy Catalogue function; Whether PCM helps with

Table 11 Evaluation related to the perception of the participants concerning the PCM

Perception of PCM tool	Median	Company	Median
Easy of use	2.0	CPY1	2.0
		CPY2	1.0
		CPY3	2.0
		CPY4	1.5
Privacy catalogue	2.0	CPY1	2.0
		CPY2	2.0
		CPY3	2.0
		CPY4	1.5
PCM helps with unfamiliar concepts	2.0	CPY1	2.5
		CPY2	2.0
		CPY3	2.0
		CPY4	2.5
PCM in specification activities	2.0	CPY1	2.0
		CPY2	2.0
		CPY3	3.0
		CPY4	2.0
PCM in developing activities	2.0	CPY1	2.0
		CPY2	2.0
		CPY3	3.0
		CPY4	1.5
PCM adoption	2.0	CPY1	1.0
		CPY2	2.0
		CPY3	2.0
		CPY4	2.0
Agile usage	2.0	CPY1	2.0
		CPY2	3.0
		CPY3	3.0
		CPY4	2.0

unfamiliar concepts; PCM assistance in specification activities; PCM assistance in developing activities; PCM adoption in software development; and Whether PCM could be used by their teams.

Regarding those questionnaire items, we observe medians of 2.0, when every participant is considered. Considering each company separately, we observe medians ranging between −2.0 and 3.0.

Therefore, the results in Table 11 give us confidence in affirming that the participants' perception showed that (RQ4): (i) PCM is easy to use; (ii) The Privacy Catalog helps the PCM usage; (iii) PCM helps understand unfamiliar

concepts; (iv)) PCM assists in privacy specification activities; (v) PCM assists in privacy development activities; (vi) PCM could be adopted in Software Development work; (vii) PCM could be adopted in Agile Software Development.

Concerning the perception of 'ease of use', we found that the participants at Company 1 reported that PCM is able to capture the concept of 'consent' very well, and the definitions were well-structured (despite the presence of a few acronyms). For example, Participant 1.1 reported: "*a) Concept of consent was captured very well. b) Definitions are structured well.*". Moreover, one participant expressed doubt regarding the overview of the combinations of privacy mechanisms and privacy risk scenarios.

The participants at Company 2 reported that PCM is easy to understand. However, they also reported that using PCM becomes easier with practice. Some language definitions were perceived as challenging, but the explanations that were provided were of assistance⁵ These participants suggested that additional documentation would have been even more helpful. The participants at Company 3 claimed that they found the concept of privacy difficult to understand. For example, concerning the concept of *privacy preferences*. Participant 3.5 reported: "*I had to read the definition of the items for each stage.*" These participants reported that the PCM template was confusing. They suggested that a description with more examples and explanations of the items was necessary. However, Participant 3.3 confirmed: "*After the concepts became clearer, the PCM proved to be quite important and practical to use.*" Participant 3.8 and Participant 3.9 also found the PCM to be clear and intuitive in its application. We thus claim that after proper training, it is possible to use PCM in practice. The participants at Company 4 reported that privacy was not a subject that they dealt with routinely. They observed that there is a great deal of new information about a specific domain that needs to be processed. Notwithstanding this, with training, they said that this process would become easier. For example, Participant 4.3 noted: "*With examples, it is easier to understand the concepts, but I still have some doubt about how certain concepts are related, for example, the Actor trust relationship.*"

Further, we asked whether any conflicts existed between PCM and the participant's team development practices. We show below text extracts, which were reported by participants. For example, Participant 1.3 thought that PCM might be more useful in the analysis phase than in the development phase. For example, "*[...] the result of using it in the requirement analysis phase would be beneficial to get as input.*". Participant 2.1 said that PCM levels of detail are seldom used when they work with requirements. Participant 3.3 pointed out that it would be useful to use PCM if it was integrated with the company's procedure.

⁵ The explanations can be accessed via the help function in the tool.

Table 12 Summary of research questions results

Research question	Evaluation	Conclusion
RQ1 (Well-formed)	Measuring the number of occurrences in artifacts produced during the task	More Well-formed correct
RQ1 (Atomic)	Measuring the number of occurrences in artifacts produced during the task	More Atomic correct
RQ1 (Minimal)	Measuring the number of occurrences in artifacts produced during the task	More Minimal correct
RQ1 (Concept. sound)	Measuring the number of occurrences in artifacts produced during the task	More Concept. sound wrong
RQ1 (Problem-oriented)	Measuring the number of occurrences in artifacts produced during the task	More Problem-oriented correct
RQ2 (Coverage)	Measurement from the good perception and thematic analysis of the post-questionnaire	PCM has good coverage
RQ3 (Usefulness)	Measurement from the good perception	PCM can be considered useful
RQ4 (Applicability)	Measurement from the good perception and thematic analysis of the post-questionnaire	PCM can be applied in software development
RQ5 (Missing or excessive privacy specification)	Measurement from thematic analysis of the post-questionnaire and the open discussion	PCM helps to remember certain privacy elements
RQ6 (Scalability)	Measurement from thematic analysis of the open discussion	PCM can be included in Software Development

4.3.4 Further observations

During the time spent with the participants of this study, we made notes in two different categories: main observations and improvements suggested by the participants.

Main observations.

Participants from Company 2 asked questions about how one can download PCM artifacts, how one can interact with the project, and questions about working with User Stories. However, they also reported that the Privacy Catalog was particularly useful, and they could use PCM in their daily work.

The participants noted that two positive points of PCM were the opportunity to enjoy more control over privacy information and to present consent in a more user-friendly way. However, to actually use PCM in their software development project, the participants reported that they needed to see what integration with their current practices would be like. They also stated that it was necessary to establish the legal basis for each artifact, as their current practice is to establish the legal basis for the whole project.

Suggested improvements received from the participants.

The participants reported PCM made them think about privacy more profoundly and that they could include PCM in their software development process, subject to PCM undergoing some adjustments and the participants receiving more training. This sentiment was raised in response to their reservations concerning the usability of PCM (an issue that more training could resolve). They recommended a solution to ensure that privacy was designed

according to the mechanisms specified by PCM at the end of the software development process. They indicated that the PCM could be improved by (i) presenting more ready-made projects in the tool that are focused on different domains, (ii) improving the reuse of the PCM (for example, the content of a privacy requirement specification with PCM can be used as a basis for specifying other privacy requirements). They also suggested integrating PCM with requirements management systems, such as JIRA. Moreover, they noted that their company's processes were distributed and subject to different cultures, which represents a complication for PCM adoption.

Finally, participants asked how PCM artifacts could be used to generate test cases.

5 Discussion of study implications

The issue of privacy is gaining more and more attention in contemporary society, thus creating circumstances where companies must comply with increasingly complex laws and regulations. In this context, the current research literature indicates that it is necessary to consider privacy as a primary concern in software development, beginning with RE [12, 59]. Thus, we developed PCM to elicit privacy concerns in software development [29].

This study aimed to answer research questions about how PCM can foster privacy in the development process from the point of view of software practitioners. In Table 12, we present an overview of the results of

the research questions. Below, we summarize our key observations.

PCM artifacts are of a high quality (RQ1). Our analysis of the artifact produced by practitioners indicated that the privacy requirements obtained using PCM are of a high quality. In particular, we conclude that the specifications produced with PCM were *Well-formed*, *Atomic*, *Minimal*, and *Problem-oriented*. However, we found that the specifications produced with PCM are not entirely *Conceptually sound*. In this sense, both our methodology and the results obtained from this study contribute to the focused research area. This should be a welcome result since, currently, there is a lack of studies focusing on empirically evaluating privacy requirements specification approaches.

PCM provides a high level of privacy specification coverage (RQ2 and RQ5). We addressed the metric relevant to PCM coverage, and we recorded concerns regarding missing or excessive privacy specifications via several questions in the post-questionnaire and in the open discussion sessions we conducted with the participants. For example, the participants reported in the post-questionnaire that parts of the PCM specification process, including the *Lawful base specification*, *Actors* and *Trust Relationship* specification, *Personal Information List* specification, the *Purpose of Personal Information Context* specification, *Privacy Constraint* specification, *Privacy Risk Scenario* specification, and the *Privacy Mechanisms* specification are all important. These parts scored a median of 3.00 in all PCM specification parts when every company is taken into account. In addition, despite some remarks concerning the inclusion of additional fields and some improvements, the practitioners we interviewed informed us that PCM helped them to remember certain privacy elements.

PCM is useful for the consideration of privacy in software development, and PCM can be applied in software development (RQ3 and RQ4). We analyzed the metrics relevant to the usefulness of PCM (RQ3) and its applicability (RQ4) in several questions in the post-questionnaire. Regarding usefulness, for example, the median of the inquiries was above 2.5. Regarding applicability, all practitioners included in this study reported that PCM helped them in their privacy specification activities and privacy development activities (a median score of 2.00 was recorded for all of the companies). This result corroborates with the conclusions from Senarath et al. [60] in which they performed an empirical study to identify the factors that influence software developers' intention to use Privacy Engineering Methodologies (PEM). A PEM's usefulness and compatibility with developers' way of work were found to significantly influence the developers' intention to adopt it.

Our result suggests that PCM has the potential to be used in Agile software development (which is related to our question on Agile usage (Median 2.0)). However, this suggestion needs to be better investigated in the agile context in order to reach a conclusion. The responses to PCM by the practitioners may be due to the fact that PCM was consciously designed to include essential quality factors for software requirements specifications in ASD [32, 37]. These factors include automated support (PCM Tool), understandability (made manifest in explicit guidelines), team-orientation (requirements are described using language that is directed towards the developer and is accompanied by a catalogue of privacy concepts), simplicity (the requirements are described as simply as possible), and objectivity (requirements are described objectively, without redundant and unnecessary details being provided to the developer) [32, 37].

PCM can be scalable (RQ6). We analyzed the metrics relevant to the scalability of PCM in the open discussion sessions with the participants. We found that the participants reported that PCM made them think more closely about privacy. They claimed that they could include PCM in their software development process, provided that certain adjustments be made to PCM and that they received more training in its use. However, despite this being a promising result, more research is necessary to confirm the scalability of PCM for software development.

The results of this study are similar to the results obtained previously, in which we carried out an evaluation of PCM with post-graduate students [29]. We performed an experiment (first empirical study) with 32 students (also IT analysts of federal educational institutions), whose objective was to evaluate PCM and user stories regarding their suitability in the area of privacy requirements specification [29]. We also conducted a qualitative study (second empirical study) with 18 post-graduate students from different areas, including IT and law. [37]. We found in the first evaluation that (i) PCM leads system analysts to focus on privacy requirements, (ii) the privacy requirements that were obtained using PCM were of high quality (Regarding Syntactic (*Well-formed*, *Atomic* and *Minimal*) and Semantics (*Conceptually sound* and *Problem-oriented*) and (iii) The effort to use PCM is not bigger than using other RE techniques [29, 37]. The second evaluation suggested that PCM provides high levels of coverage, applicability, usefulness, and ease of use in the domain of privacy requirements specification from a system student's perspective [29, 37].

Our results on the characterization of privacy are consistent with our previous study and other authors' studies. For example, the confusion between privacy and security agrees with what was found by [9, 30]. In this regard, [61] argue that, despite the overlap between engineering requirements for privacy and engineering requirements for security, each requirements process addresses a different set of problems.

6 Threats to validity

We report the construct validity, internal validity, external validity and reliability as defined in [50].

Construct validity reflects the extent to which operational measures represent what the researcher wants to investigate according to the researcher's stated research questions. This means that it is necessary to carefully develop operational measures to ensure that we measure what we want correctly. In the present study, we address this threat by using established measurement approaches reported in previous literature. The same metrics were used in our previous evaluation of PCM with students [29]. Furthermore, we conducted rounds of validation of the instruments with the researchers involved. However, we noticed some misinterpretations. For example, regarding the questionnaires, the participants asked whether Question 2 in the post-questionnaire should be answered from the developer's or user's perspectives. They also asked for clarification about privacy constraints, privacy mechanisms, the actor's and owner's trust (for example, if the "processor" could be anything other than the system), and what private data could be shared and what data could not be shared with others. In the situations above, we clarified at the same time that doubts occurred.

Internal validity considers whether factors other than those identified by the researcher may have influenced the results of a study. For example, the sample included in the present study is composed of individuals with different roles and years of experience. The participants also represent companies from different domains. We made participants comfortable by ensuring that their identities were not disclosed and that all of the materials produced during the study (for example, results, reports, and scientific papers) would be presented to each company before disclosing them.

Regarding our sample choice decision, it is worth noting that many companies do not have a dedicated Requirements Engineer role [57]. Additionally, practitioners may encounter confusion between the concepts of role and position [57]. On the other hand, in a study focused on Requirements Engineering, one would expect Requirements Engineers to constitute a significant portion of the sample. We opted not to restrict the sample for the reasons mentioned above and to acknowledge the importance of capturing perspectives from various stakeholders who interact with requirements engineering processes. In fact, Designers, Architects, Testers, Managers, Product Owners, and Developers, among others, can provide valuable insights into usability, implementation challenges, and practical considerations that complement the feedback from Requirements Engineers on requirements specification. Therefore, it is crucial to recognize that the composition of our participant sample, particularly the low

representation of Requirements Engineers, may raise concerns about the validity of our findings.

External validity is concerned with the extent to which it is possible to generalize the results of a study. We could not assess the development aspect to its fullest extent due to the time limits imposed by the workshop and participants' availability. For a complete evaluation of the software development, it would be necessary to follow a project throughout its development life cycle. Although the 21 practitioners involved in the study found PCM useful for specifying requirements, we could not generalize this study's results due to the limited variety of participants and companies.

Reliability is concerned with the extent to which the data and analysis depend on the specific researcher(s) who conducted the study. In other words, we have to ensure the stability and repeatability of the measures. To mitigate this threat, we followed a clearly stated method and conducted several rounds of discussion among the involved researchers before and after the case studies. In addition, the case studies and data analysis were carried out by more than one person and the first author (the author of the PCM) participated in all workshops and all data analysis.

7 Conclusion and Future Work

This paper presented an evaluation of PCM by performing an empirical study in multiple software development companies. This study was based on a five-step workshop with a total of twenty-one practitioners from four companies.

With respect to the software development process, we initially observed that practitioners perceived their respective companies as working in an agile manner, using heterogeneous teams. The results obtained are promising, but they do not assure the suitability of PCM for agile software development. This evaluation of PCM in an industrial context also helped us gather more evidence that the metrics we used and our evaluation protocol can be adopted in other studies on the same topic.

Besides assisting in specifying privacy requirements, PCM is also intended to promote a better understanding of privacy among the members of the development team and supports the specification of privacy requirements independently of the data protection law and software process required in the project.

It is important to note that we designed the PCM to complement any requirements specification technique. In our future efforts, we are committed to evaluating the compatibility of our method with new development processes, such as Continuous Software Engineering. Recognizing the crucial role of the method's adaptability and flexibility in real-world implementation, our upcoming research will

concentrate on refining the PCM to align seamlessly with diverse organizational contexts.

In ongoing efforts, we are currently considering improvement suggestions, including transitioning the PCM Tool to the university web server, enabling the export of PCM-generated privacy artifacts to a PDF file, integrating the PCM Tool with JIRA Software, and utilizing the PCM artifact to guide privacy testing. As these enhancements are ongoing, re-evaluating PCM remains a focus for future research endeavors.

Therefore, as future work, we need to conduct a study on the application of PCM during the development of different products and services by Agile teams. Future work also includes: (i) evaluating whether PCM helps to improve the privacy culture in organization; (ii) evaluating whether PCM artifacts contribute to data protection laws compliance; (iii) evolving the PCM Tool by improving its technical aspects, including its scalability and usability; (iv) evolving the PCM tool by enabling the reuse of PCM artifacts across different projects and enabling its integration with tools already in use in the company (e.g. project management tool); (v) investigating potential changes in the use of information sources by practitioners that adopted PCM.

8 Supplementary information

In the supplementary material, we disclose the instruments we used in the workshops. However, we cannot disclose the collected data due to confidentiality. Supplementary material link: <https://zenodo.org/badge/latestdoi/220078896>.

Acknowledgements Part of this study was funded by the Coordenação de Aperfeiçoamento de Pessoal de Nível Superior - Brasil (CAPES) (Finance Code 001), and the KKS foundation through the S.E.R.T. Research Profile project at Blekinge Institute of Technology.

Declarations

Conflict of interest The authors declare that they have no Conflict of interest.

Ethics approval Ethical considerations need to be addressed when research involves humans. Therefore, the participants were informed of the research objectives when the studies were scheduled. In addition, the participants were informed that their identities would be kept confidential. Also, they answered an Informed consent document.

References

- Curcio K, Navarro T, Malucelli A, Reinehr S (2018) Requirements engineering: A systematic mapping study in agile software development. *J Syst Softw* 139:32–50
- Behutiye W, Karhapää P, Costal D, Oivo M, Franch X (2017) Non-functional requirements documentation in agile software development: challenges and solution proposal. In: *International Conference on Product-focused Software Process Improvement*, pp. 515–522. Springer
- Jarzkebowicz A, Weichbroth P (2021) A qualitative study on non-functional requirements in agile software development. *IEEE Access* 9:40458–40475. <https://doi.org/10.1109/ACCESS.2021.3064424>
- Kasauli R, Liebel G, Knauss E, Gopakumar S, Kanagwa B (2017) Requirements engineering challenges in large-scale agile system development. In: *Requirements Engineering Conf. (RE)*, 2017 IEEE 25th International, pp. 352–361. IEEE
- Wagner S, Méndez D, Felderer M, Vetrò A, Kalinowski M, Wieringa R, Pfahl D, Conte T, Christiansson M-T, Greer D, Lassenius C, Männistö T, Nayebi M, Oivo M, Penzenstadler B, Prikladnicki R, Ruhe G, Schekelmann A, Sen S, Spínola R, Tuzcu A, De La Vara JL, Winkler D (2019) Status Quo in Requirements Engineering: A Theory and a Global Family of Surveys. *ACM Trans. on Software Engineering and Methodology (TOSEM)* 28(2):9
- Eckhardt J, Vogelsang A, Méndez D (2016) Are “non-functional” requirements really non-functional? an investigation of non-functional requirements in practice. In: *Proceedings of the 38th International Conference on Software Engineering*, pp. 832–842
- Gharib M, Giorgini P, Mylopoulos J (2017) Towards an ontology for privacy requirements via a systematic literature review. In: *International Conference on Conceptual Modeling*, pp. 193–208. Springer
- Gharib M, Mylopoulos J, Giorgini P (2020) Copri-a core ontology for privacy requirements engineering. In: *International Conference on Research Challenges in Information Science*, pp. 472–489. Springer
- Hadar I, Hasson T, Ayalon O, Toch E, Birnhack M, Sherman S, Balissa A (2018) Privacy by designers: software developers’ privacy mindset. *Empirical Softw Eng* 23(1):259–289
- Thomas K, Bandara AK, Price BA, Nuseibeh B (2014) Distilling privacy requirements for mobile applications. In: *Proceedings of the 36th International Conference on Software Engineering*, pp. 871–882. ACM
- Kalloniatis C, Kavakli E, Gritzalis S (2008) Addressing privacy requirements in system design: the Pris method. *Requirements Eng* 13(3):241–255
- Canedo E, Calazans A, Cerqueira A, Costa P, Masson E (2021) Agile teams’ perception in privacy requirements elicitation: Lgpd’s compliance in brazil. In: *Requirements Engineering Conf. (RE)*, 2021 IEEE 29th International, pp. 352–361. IEEE
- Canedo ED, Calazans ATS, Bandeira IN, Costa PHT, Masson ETS (2022) Guidelines adopted by agile teams in privacy requirements elicitation after the Brazilian general data protection law (LGPD) implementation. *Requirements Eng* 27(4):545–567. <https://doi.org/10.1007/s00766-022-00391-7>
- Peixoto M, Ferreira D, Cavalcanti M, Silva C, Vilela J, Araújo J, Gorschek T (2023) The perspective of Brazilian software developers on data privacy. *J Syst Softw* 195:111523. <https://doi.org/10.1016/j.jss.2022.111523>
- Senarath A, Arachchilage NA (2018) Why developers cannot embed privacy into software systems? an empirical investigation. In: *Proceedings of the 22nd International Conference on Evaluation and Assessment in Software Engineering 2018*, pp. 211–216
- Usman M, Felderer M, Unterkalmsteiner M, Klotins E, Mendez D, Alégroth E (2020) Compliance requirements in large-scale software development: An industrial case study. In: *International Conference on Product-Focused Software Process Improvement*, pp. 385–401. Springer
- Bijwe A, Mead NR (2010) Adapting the square process for privacy requirements engineering. Technical report, Technical report.

- https://resources.sei.cmu.edu/asset_files/technicalnote/2010_004_001_15185.pdf
18. Ayala-Rivera V, Pasquale L (2018) The grace period has ended: An approach to operationalize gdpr requirements. In: 2018 IEEE 26th International Requirements Engineering Conference (RE), pp. 136–146. <https://doi.org/10.1109/RE.2018.00023>. IEEE
 19. Elahi G, Yu E, Zannone N (2010) A vulnerability-centric requirements engineering framework: analyzing security attacks, countermeasures, and requirements based on vulnerabilities. *Requirements Eng* 15:41–62
 20. Deng M, Wuyts K, Scandariato R, Preneel B, Joosen W (2011) A privacy threat analysis framework: supporting the elicitation and fulfillment of privacy requirements. *Requirements Eng* 16(1):3–32
 21. Labda W, Mehdiyev N, Sampaio P (2014) Modeling of privacy-aware business processes in BPMN to protect personal data. In: Proceedings of the 29th Annual ACM Symposium on Applied Computing, pp. 1399–1405. ACM
 22. Araújo E, Vilela J, Silva C, Alves C (2021) Are my business process models compliant with lgpd? the lgpd4bp method to evaluate and to model LGPD aware business processes. In: Proceedings of the XVII Brazilian Symposium on Information Systems. SBSI '21. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3466933.3466982>
 23. Mouratidis H, Giorgini P, Manson G (2005) When security meets software engineering: a case of modelling secure information systems. *Inform Syst* 30(8):609–629
 24. Mouratidis H, Islam S, Kalloniatis C, Gritzalis S (2013) A framework to support selection of cloud providers based on security and privacy requirements. *J Syst Softw* 86(9):2276–2293
 25. European-Union: GDPR - General Data Protection Regulation. <https://eugdpr.org/> (2018)
 26. Bartolini C, Daoudagh S, Lenzini G, Marchetti E (2019) Gdpr-based user stories in the access control perspective. In: International Conference on the Quality of Information and Communications Technology, pp. 3–17. Springer
 27. Peixoto MM, Silva C, Maia H, Araújo J (2020) Towards a catalog of privacy related concepts. In: Joint Proceedings of REFSQ-2020 Workshops, Doctoral Symposium, Live Studies Track, and Poster Track, Pisa, Italy. <https://ceur-ws.org/Vol-2584/PT-paper5.pdf>
 28. Peixoto M, Silva C, Lima R, Araújo J, Gorschek T, Silva J (2019) PCM Tool: Privacy Requirements Specification in Agile Software Development. In: Brazilian Conference on Software: Theory and Practice (CBSOFT), pp. 108–113. https://doi.org/10.5753/cbsoft_estendido.2019.7666. SBC
 29. Peixoto M, Silva C, Araújo J, Gorschek T, Vasconcelos A, Vilela J (2022) Evaluating a privacy requirements specification method by using a mixed-method approach: results and lessons learned. *Requirements Eng*. <https://doi.org/10.1007/s00766-022-00388-2>
 30. Peixoto M, Ferreira D, Cavalcanti M, Silva C, Vilela J, Araújo J, Gorschek T (2020) On understanding how developers perceive and interpret privacy requirements research preview. In: International working conference on requirements engineering: Foundation for software quality, pp. 116–123. https://doi.org/10.1007/978-3-030-44429-7_8. Springer
 31. Glinz M (2011) A glossary of requirements engineering terminology. Standard Glossary of the Certified Professional for Requirements Engineering (CPRE) Studies and Exam, Version. Vol. 1, p. 56
 32. Medeiros J, Vasconcelos A, Silva C, Goulão M (2018) Quality of software requirements specification in agile projects: A cross-case analysis of six companies. *J Syst Softw* 142:171–194
 33. Lucassen G, Dalpiaz F, Werf JME, Brinkkemper S (2016) Improving agile requirements: the quality user story framework and tool. *Requirements Eng* 21(3):383–403
 34. Kasauli R, Knauss E, Horkoff J, Liebel G, Oliveira Neto FG (2021) Requirements engineering challenges and practices in large-scale agile system development. *J Syst Softw* 172:110851
 35. Schön E-M, Winter D, Escalona MJ, Thomaschewski J (2017) Key challenges in agile requirements engineering. In: International conference on Agile software development, pp. 37–51. Springer, Cham
 36. Fernández DM, Wagner S, Kalinowski M, Felderer M, Mafra P, Vetrò A, Conte T, Christiansson M-T, Greer D, Lassenius C et al (2017) Naming the pain in requirements engineering: Contemporary problems, causes, and effects in practice. *Emp Softw Eng* 22:2298–2338
 37. Peixoto MM (April 2021) A privacy requirements specification method for agile software development based on exploratory studies. PhD thesis, Universidade Federal de Pernambuco, Recife-Brazil. <https://repositorio.ufpe.br/handle/123456789/40286>
 38. Cavoukian A (2009) Privacy by design: The 7 foundational principles. *Inf Privacy Commiss Ontario, Canada*. 5:1–5
 39. Antón AI, Earp JB (2001) Strategies for developing policies and requirements for secure and private electronic commerce. In: E-commerce security and privacy, pp. 67–86. https://doi.org/10.1007/978-1-4615-1467-1_5. Springer
 40. Ayed GB, Ghernaoui-Hélie S (2011) Privacy requirements specification for digital identity management systems implementation: towards a digital society of privacy. In: Internet technology and secured transactions (ICITST), 2011 international conference, pp. 602–607. IEEE. <https://ieeexplore.ieee.org/document/6148406>
 41. Viitaniemi M (2017) Privacy by design in agile software development. Master's thesis, Tampere University of Technology. <https://urn.fi/URN:NBN:fi:tyy-201711162157>
 42. Rygge H, Jøsang A (2018) Threat poker: Solving security and privacy threats in agile software development. In: Nordic conference on secure IT systems, pp. 468–483. Springer
 43. Basso T, Montecchi L, Moraes R, Jino M, Bondavalli A (2015) Towards a uml profile for privacy-aware applications. In: 2015 IEEE international conference on computer and information technology; ubiquitous computing and communications; dependable, autonomic and secure computing; pervasive intelligence and computing, pp. 371–378. IEEE
 44. Izquierdo JLC, Salas J (2018) A uml profile for privacy enforcement. In: Federation of international conferences on software technologies: applications and foundations, pp. 609–616. Springer
 45. Mai PX (2018) al: Modeling security and privacy requirements: a use case-driven approach. *Inf Softw Technol* 100:165–182
 46. Pullonen P, Matulevičius R, Bogdanov D (2017) PE-BPMN: privacy-enhanced business process model and notation. In: International conference on business process management, pp. 40–56. Springer
 47. Baldassarre MT, Santa Barletta V, Caivano D, Scalera M (2020) Integrating security and privacy in software development. *Software Qual J* 28(3):987–1018. <https://doi.org/10.1007/s11219-020-09501-6>
 48. Tsohou A, Magkos E, Mouratidis H, Chrysoloras G, Piras L, Pavlidis M, Debussche J, Rotoloni M, Crespo BG-N (2020) Privacy, security, legal and technology acceptance elicited and consolidated requirements for a GDPR compliance platform. *Inf Comput Secur* 28(4):531–553
 49. Wuyts K, Sion L, Joosen W (2020) Linddun go: A lightweight approach to privacy threat modeling. In: 2020 IEEE european symposium on security and privacy workshops (EuroS&PW), pp. 302–309. <https://doi.org/10.1109/EuroSPW51379.2020.00047>
 50. Runeson P, Höst M (2009) Guidelines for conducting and reporting case study research in software engineering. *Empirical Softw Eng* 14(2):131
 51. Svensson RB, Gorschek T, Regnell B, Torkar R, Shahrokni A, Feldt R (2011) Quality requirements in industrial practice—an

- extended interview study at eleven companies. *IEEE Trans Software Eng* 38(4):923–935
52. Wohlin C, Runeson P, Höst M, Ohlsson MC, Regnell B, Wesslén A (2012) *Experimentation in software engineering*. Springer, Berlin. <https://doi.org/10.1007/978-3-642-29044-2>
 53. Vilela J, Castro J, Martins LEG, Gorschek T (2020) Safety practices in requirements engineering: The uni-repm safety module. *IEEE Trans Software Eng* 46(3):222–250
 54. Nguyen M (September 2010) Empirical evaluation of a universal requirements engineering process maturity model. Master's thesis, School of Engineering, Blekinge Institute of Technology, Sweden. <https://www.diva-portal.org/smash/get/diva2:831329/FULLTEXT01.pdf>
 55. Baltes S, Ralph P (2022) Sampling in software engineering research: A critical review and guidelines. *Empirical Softw Eng* 27(4):94
 56. Sawyer P, Kotonya G (2001) *Software requirements*. SWEBOK, 9
 57. Franch X, Palomares C, Gorschek T (2021) On the requirements engineer role. *Commun ACM* 64(6):69–75
 58. Cruzes DS, Dyba T (2011) Recommended steps for thematic synthesis in software engineering. In: 2011 international symposium on empirical software engineering and measurement, pp. 275–284. IEEE
 59. Dias Canedo E, Toffano Seidel Calazans A, Toffano Seidel Masson E, Teixeira Costa PH, Lima F (2020) Perceptions of ict practitioners regarding software privacy. *Entropy* 22(4):429
 60. Senarath A, Grobler M, Arachchilage NAG (2019) Will they use it or not? investigating software developers' intention to follow privacy engineering methodologies. *ACM Trans. Priv. Secur.* 22(4) <https://doi.org/10.1145/3364224>
 61. Abu-Nimeh S, Mead NR (2009) Privacy risk assessment in privacy requirements engineering. In: 2009 second international workshop on requirements engineering and law, pp. 17–18. <https://doi.org/10.1109/RELAW.2009.10>. IEEE

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.

Springer Nature or its licensor (e.g. a society or other partner) holds exclusive rights to this article under a publishing agreement with the author(s) or other rightsholder(s); author self-archiving of the accepted manuscript version of this article is solely governed by the terms of such publishing agreement and applicable law.